

Leakage-Audited Metadata-Only Intrusion Detection for Encrypted MQTT-Based IoT Traffic

Dun Li , Hongzhi Li , Noel Crespi , Wei Liang 

Abstract—MQTT-based Internet of Things (IoT) deployments require intrusion detection mechanisms that remain useful when payload inspection is unavailable. Payload encryption, Transport Layer Security (TLS), and privacy constraints make payload-, topic-, credential-, and client-identifier-based intrusion detection difficult to justify in operational monitoring. This paper presents LAM-MQTT, a leakage-audited metadata-only evaluation framework for encrypted MQTT intrusion detection. The framework separates hard leakage fields from legitimate encrypted-flow metadata and evaluates audited, conservative, and common cross-dataset feature policies on MQTTEEB-D, MQTT-IoT-IDS2020, and IoT-23. The results show that encrypted-flow metadata supports effective within-dataset detection: MQTT-IoT-IDS2020 audited metadata reaches 0.9991 Macro F1, conservative sensitivity reduces this result to 0.9684, and MQTTEEB-D strict 5 s flow-window metadata reaches 0.8925. However, MQTT-to-MQTT transfer is asymmetric and window-dependent, and IoT-23 external robustness remains modest. Metadata-only IDS is therefore useful under cryptographic observability constraints, but it is not a replacement for cryptographic authentication, access control, or protocol hardening.

Index Terms—Encrypted traffic analysis, intrusion detection, leakage audit, metadata-only monitoring, MQTT, IoT security.

I. INTRODUCTION

MESSAGE Queuing Telemetry Transport (MQTT) is a lightweight publish-subscribe protocol widely used in IoT and Industrial Internet of Things (IIoT) environments [1], [2]. MQTT clients publish telemetry to a broker, while subscribers receive messages through topic-based routing. This architecture is attractive for resource-constrained devices because it decouples producers and consumers and reduces communication overhead. It also creates an operational security challenge: compromised clients, abnormal publish/subscribe patterns, denial-of-service behavior, brute-force attempts, and malformed protocol interactions can all appear in broker-mediated traffic. These behaviors are often reflected in connection dynamics before they are visible as application-level failures.

In practical deployments, MQTT monitoring is often positioned at the broker, gateway, or network edge rather than

inside each constrained device. Such monitors may observe connection behavior and packet dynamics, but they cannot necessarily inspect application semantics. This creates a gap between conventional intrusion detection features, which may assume access to protocol content or endpoint identifiers, and what is actually available in privacy-preserving or encrypted deployments. Similar observability gaps have been studied in encrypted traffic analysis, where protected channels can still expose measurable trace structure [3].

The monitoring setting is increasingly constrained by encryption and privacy requirements. TLS protects application content in transit [4]; privacy policies and deployment boundaries may also prevent inspection of raw payloads, raw topic strings, usernames, passwords, client identifiers, and raw IP identities. Intrusion detection systems (IDSs) that rely on such fields can therefore be difficult to deploy, reproduce, or justify. Website fingerprinting and modern encrypted-traffic representation learning further show that packet length, timing, and sequence regularities can remain informative even when content is hidden [5], [6]. This motivates metadata-only detection: instead of inspecting content, a detector can use flow duration, packet counts, byte statistics, packet-size statistics, inter-arrival-time (IAT) statistics, rates, burstiness, and TCP flag counts, a direction consistent with prior flow and encrypted-traffic analysis [7], [8].

Fig. 1 illustrates this encrypted MQTT monitoring setting.

The central question is therefore not whether metadata can replace protocol security, but whether a carefully bounded metadata signal can provide an additional detection layer. Such a layer is complementary to access-control and data-governance mechanisms for IIoT, including smart-contract and proof-inspired access-control schemes [9], [10]. Answering this question requires an explicit observability model: features should be admitted only when they would plausibly remain available without decrypting traffic or collecting sensitive raw fields.

Metadata-only detection is useful but risky. It is useful because many attacks alter observable communication dynamics even when payloads are encrypted. It is risky because public security datasets can contain artifacts that inflate within-dataset scores, including labels, attack-category fields, scenario names, source-file indicators, exact timestamps, and raw identity fields. Security-ML evaluation critiques have repeatedly warned that hidden bias and unrealistic experimental design can lead to overconfident claims [11], [12]. Random within-dataset splits can further overestimate deployment performance when dataset-specific patterns are shared between training and test partitions. A credible evaluation must

Dun Li is with the Department of Industrial Engineering, Tsinghua University, China, and Samovar, Telecom SudParis, Institut Polytechnique de Paris, 91120 Palaiseau, France. E-mail: lidunshmtu@outlook.com

Hongzhi Li is with the College of Big Data and Artificial Intelligence, Chizhou University, Chizhou 247100, China. Email: pickpickup@sohu.com

Noel Crespi is with Samovar, Telecom SudParis, Institut Polytechnique de Paris, 91120 Palaiseau, France. Email: noel.crespi@mines-telecom.fr

Wei Liang is with the School of Computer Science and Engineering, Hunan University of Science and Technology, and Hunan Key Laboratory for Service Computing and Novel Software Technology, China. E-mail: wliang@hnust.edu.cn

Corresponding Authors: Noel Crespi, Hongzhi Li

MQTT-based IoT traffic under encrypted monitoring

Publish/subscribe telemetry is broker mediated; raw MQTT content is hidden while flow behavior remains observable

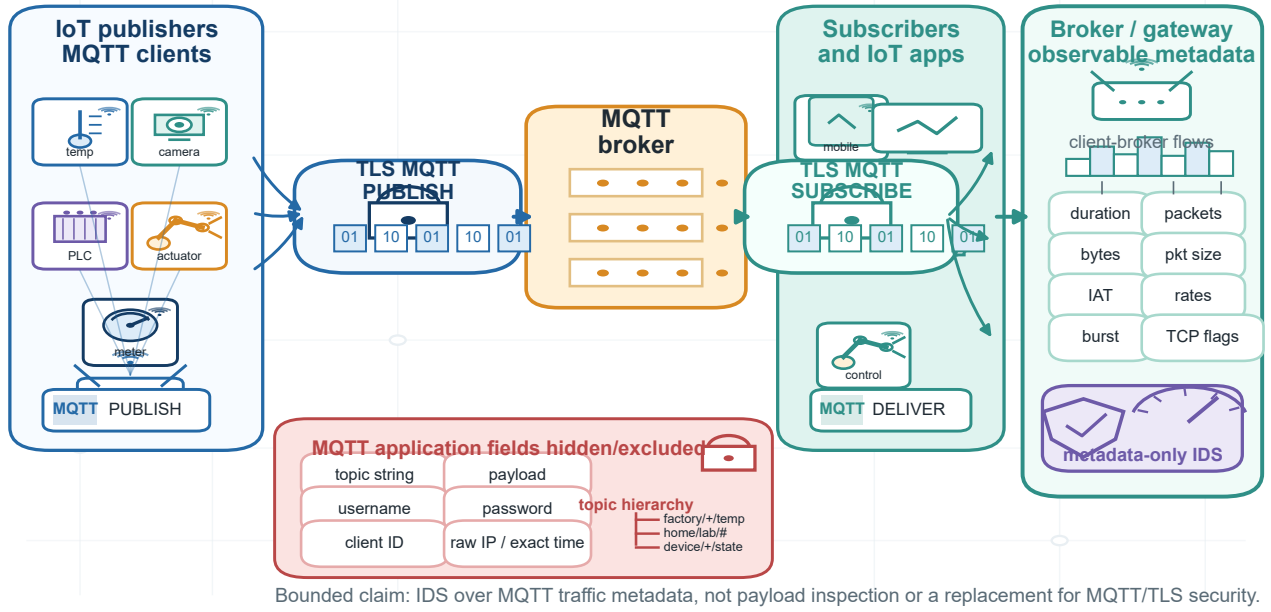


Fig. 1: MQTT-based IoT traffic observability under encrypted broker-mediated monitoring. IoT publishers and subscribers communicate with an MQTT broker through TLS-protected PUBLISH/SUBSCRIBE flows; payloads, raw topics, credentials, client identifiers, raw IP identities, and exact timestamps are excluded, while broker-side flow metadata remains observable.

therefore distinguish legitimate encrypted-flow metadata from hard leakage, and it must evaluate robustness beyond a single random split.

This paper makes four contributions.

- We formulate encrypted MQTT intrusion detection under cryptographic observability constraints.
- We develop a leakage-audited metadata construction procedure that separates hard leakage from legitimate encrypted-flow metadata.
- We evaluate audited, conservative, and common cross-dataset feature policies on MQTTEEB-D, MQTT-IoT-IDS2020, and IoT-23.
- We show that metadata-only detection is effective within dataset, but cross-dataset transfer is asymmetric and external IoT robustness remains limited.

The remainder of this paper is organized as follows. Section II reviews related work, Section III presents LAM-MQTT, Section IV reports the experiments and findings, and Section V concludes the paper.

II. RELATED WORK

A. MQTT and IoT Intrusion Detection

Machine-learning-based IoT intrusion detection has been studied extensively because IoT deployments combine constrained devices, heterogeneous protocols, and exposed network services [13]–[15]. Broader IIoT security work has also

emphasized trustworthy data exchange, blockchain-supported governance, and digital-twin security as complementary protection layers [16]. MQTT is a particularly important protocol in this context. Its broker-mediated publish-subscribe model is efficient, but weak authentication, insecure deployment choices, broker exposure, and abnormal publish/subscribe behavior can produce detectable network-level symptoms. MQTT-focused benchmarks, including MQTTset, have made attack detection experimentally tractable, but their use still requires careful feature auditing [17].

Several broader IoT and IIoT corpora provide additional context. CICIOT2023, ToN-IoT, Bot-IoT, N-BaIoT, and Edge-IIoTset cover different attack surfaces, device types, and collection environments [18]–[22]. IoT botnet studies, including Mirai analyses, further show that compromised devices can generate large-scale network effects that are visible in timing, volume, and connection behavior [23], [24]. These corpora support benchmarking, but they also differ substantially in capture setup, labels, feature definitions, and attack distributions.

B. Encrypted Traffic Analysis and Metadata-Only Monitoring

Encrypted traffic analysis has long used timing, direction, and size metadata when payload inspection is unavailable. Classical traffic-classification work used Bayesian models and flow statistics to infer application classes without relying only on port numbers [25]. Mobile and encrypted-application

fingerprinting work further demonstrated that packet sizes and timing can reveal behavioral structure even when content is protected [26], [27]. Deep learning studies later explored packet-sequence and representation-learning approaches for encrypted traffic classification [28]–[31]. IoT traffic classifiers also use convolutional and recurrent models over flow or packet representations [32], [33].

This paper differs from payload-oriented and packet-content approaches by enforcing a metadata-only boundary. The goal is not to decrypt TLS, bypass cryptographic protection, or replace authentication and access control. Instead, the objective is to test how far legitimate encrypted-flow metadata can support IDS decisions when content and raw identities are not used.

C. Dataset Leakage, Dataset Bias, and Cross-Dataset IDS Evaluation

Network IDS evaluation is vulnerable to closed-world assumptions. Sommer and Paxson emphasized the gap between machine-learning success in controlled settings and operational network intrusion detection [34]. Dataset surveys similarly show that benchmark suitability depends on capture environment, labeling, feature construction, attack diversity, and temporal realism [35]. More generally, dataset shift and transfer-learning studies show that training and test distributions often differ in real deployments [36], [37].

For metadata-only MQTT IDS, this means that a high random-split score is not sufficient. Features must be checked for leakage, and models should be evaluated under conservative sensitivity, cross-dataset transfer, and external robustness settings. Hard leakage and dataset-specific artifacts must be separated from legitimate metadata that is predictive because attack behavior changes flow dynamics.

D. Public IoT Security Datasets and MQTT Benchmarks

Public security datasets have shaped IDS evaluation, including CICIDS2017 and UNSW-NB15 for general network intrusion detection [38], [39]. Flow-based IDS surveys and online anomaly detectors such as Kitsune reinforce the practical value of compact network metadata for high-speed or resource-constrained monitoring [40]–[44]. These datasets and methods are complementary rather than interchangeable. In particular, external IoT datasets should not be treated as MQTT benchmarks unless their capture protocol and feature space support that interpretation.

III. METHODOLOGY

A. LAM-MQTT Overview

We define LAM-MQTT, a Leakage-Audited Metadata Framework for Encrypted MQTT Intrusion Detection. The framework is designed to evaluate what can be learned from metadata that remains observable under encryption or privacy-constrained monitoring. Fig. 2 summarizes the pipeline.

The pipeline contains six steps. First, datasets are ingested and labels are normalized for binary and multiclass tasks. Second, hard leakage fields are excluded. Third, cryptographic

observability views are constructed. Fourth, a conservative sensitivity policy removes additional highly discriminative metadata. Fifth, a common cross-dataset metadata space aligns MQTT datasets for transfer evaluation. Sixth, within-dataset, cross-dataset, external robustness, feature-family, and multi-seed protocols are evaluated.

B. Dataset Ingestion and Label Normalization

The evaluation uses MQTTEEB-D [45], MQTT-IoT-IDS2020 [46], and IoT-23 [47]. MQTTEEB-D is evaluated in two granularities. The packet-level strict view is retained as a weak baseline because it contains only a very small strict metadata set. The flow-window strict view is the main encrypted-flow representation for MQTTEEB-D and is evaluated at 1 s, 5 s, and 10 s windows. MQTT-IoT-IDS2020 is evaluated using biflow features. IoT-23 is used only for external IoT robustness validation. Labels are normalized into binary and multiclass targets where appropriate; no label or attack-name field is retained as a model input.

C. Hard Leakage Exclusion

LAM-MQTT removes hard leakage before model training. The removed categories include labels, attack categories, scenario names, source-file indicators, raw IP identities, exact timestamps, client identifiers, usernames, passwords, payload content, and raw topic strings. These fields either encode the target directly, identify the capture or scenario, or violate encrypted/privacy-constrained deployment assumptions.

The framework retains legitimate metadata: duration, packet counts, byte statistics, packet-size statistics, IAT statistics, rates, burstiness, and TCP flag counts. High single-feature discriminative ability does not automatically imply leakage. A flow statistic can be highly predictive because an attack changes communication timing or volume; such a feature is treated as legitimate metadata unless it encodes labels, identities, scenarios, or unavailable content.

D. Feature Policy Definitions

Let $\mathcal{X}$ denote the set of candidate fields after dataset parsing. LAM-MQTT defines a hard leakage set $\mathcal{H}$ containing labels, attack categories, scenario names, source files, raw IP identities, exact timestamps, client identifiers, usernames, passwords, payload content, and raw topic strings. It also defines a legitimate metadata set $\mathcal{M}$ containing duration, packet and byte statistics, packet-size statistics, IAT statistics, rates, burstiness, and TCP flags. The three feature policies are

$$\mathcal{F}_{\text{main}} = \mathcal{X} \setminus \mathcal{H}, \quad (1)$$

$$\mathcal{F}_{\text{cons}} = \mathcal{F}_{\text{main}} \setminus \mathcal{S}, \quad (2)$$

$$\mathcal{F}_{\text{common}}^{a,b} = \mathcal{F}_{\text{main}}^a \cap \mathcal{F}_{\text{main}}^b \cap \mathcal{M}. \quad (3)$$

Here, $\mathcal{S}$ is the set of additional highly discriminative metadata removed only for conservative sensitivity analysis. The common policy $\mathcal{F}_{\text{common}}^{a,b}$ is applied after semantic alignment of feature names across source dataset a and target dataset b . High single-feature predictiveness alone does not move a feature from $\mathcal{M}$ to $\mathcal{H}$; a metadata feature is excluded as hard

LAM-MQTT pipeline for MQTT-based IoT traffic

Packet, biflow, and flow-window metadata are audited before within-dataset and transfer evaluation

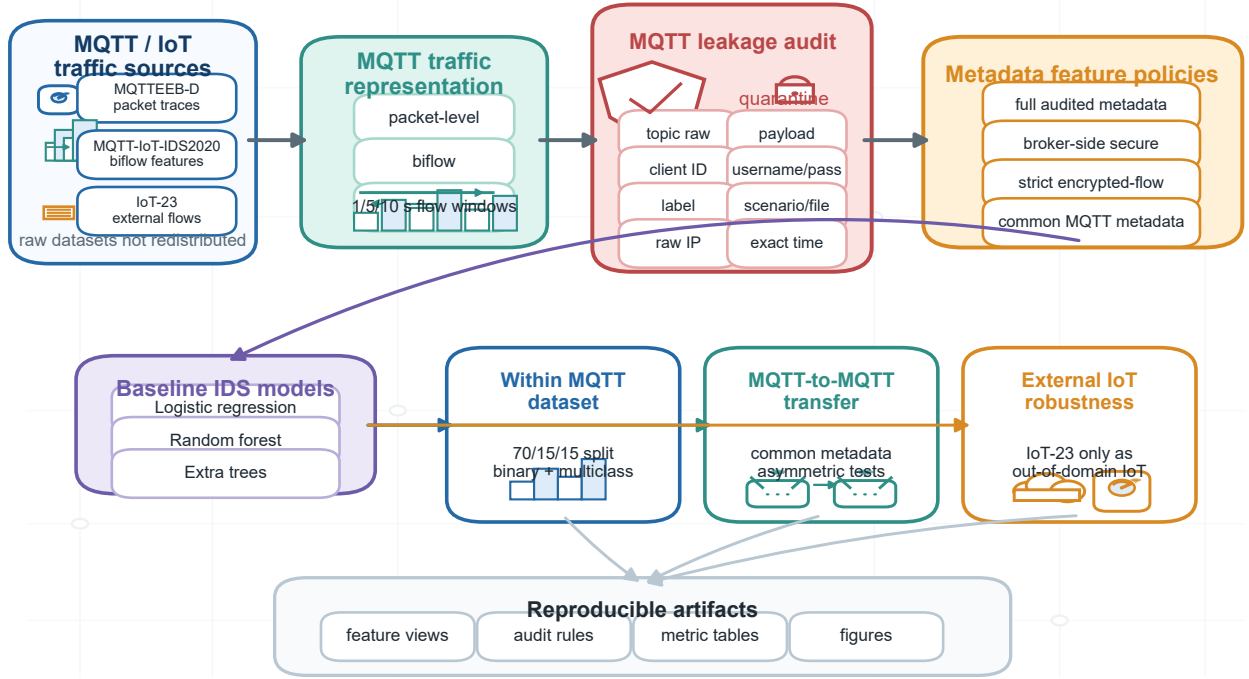


Fig. 2: LAM-MQTT pipeline for MQTT-based IoT traffic. Packet traces, biflow features, and flow-window metadata are passed through MQTT-aware leakage audit, observability feature policies, baseline IDS models, and within-dataset, MQTT-to-MQTT, and external IoT robustness evaluations.

Algorithm 1 LAM-MQTT feature policy construction

Require: Candidate fields $\mathcal{X}$, leakage rules $\mathcal{H}$, metadata vocabulary $\mathcal{M}$

Ensure: $\mathcal{F}_{\text{main}}$, $\mathcal{F}_{\text{cons}}$, $\mathcal{F}_{\text{common}}$

- 1: Remove all hard leakage fields in $\mathcal{H}$ from $\mathcal{X}$
- 2: Set $\mathcal{F}_{\text{main}} \leftarrow \mathcal{X} \setminus \mathcal{H}$
- 3: Build observability views from fields consistent with $\mathcal{M}$
- 4: Identify $\mathcal{S}$ for conservative sensitivity without relabeling $\mathcal{S}$ as leakage
- 5: Set $\mathcal{F}_{\text{cons}} \leftarrow \mathcal{F}_{\text{main}} \setminus \mathcal{S}$
- 6: Align semantically equivalent metadata names across datasets
- 7: Set $\mathcal{F}_{\text{common}}^{a,b} \leftarrow \mathcal{F}_{\text{main}}^a \cap \mathcal{F}_{\text{main}}^b \cap \mathcal{M}$

leakage only when it directly encodes the target, a capture artifact, raw identity, exact time, or content unavailable under the encrypted monitoring model.

E. Cryptographic Observability Views

LAM-MQTT constructs three observability views (Fig. 3). The full audited view is an upper-bound metadata setting after hard leakage removal. The broker-side secure metadata view represents features plausibly available near the MQTT broker without raw sensitive content. The strict encrypted-flow view

TABLE I: Audited metadata feature counts by dataset and observability view.

Dataset	Full	Broker	Strict
MQTTEEB-D	9	9	2
MQTT-IoT	42	42	42
IoT-23	31	–	31
MQTTEEB-D flow 1 s	15	15	14
MQTTEEB-D flow 5 s	15	15	14
MQTTEEB-D flow 10 s	15	15	14

Dataset sources: MQTTEEB-D [45]; MQTT-IoT-IDS2020 [46]; IoT-23 [47].

contains features expected to remain observable even when payloads and topics are encrypted.

Table I reports the audited feature counts. For MQTT-to-MQTT transfer, the framework aligns 14 common metadata features: packet count, byte summary statistics, duration, IAT summary statistics, byte and packet rates, and burstiness.

F. Flow-Window Aggregation

For MQTTEEB-D, packet-level records are additionally aggregated into fixed time windows $\Delta \in \{1, 5, 10\}$ seconds. Within each window, LAM-MQTT computes duration, packet count, byte summary statistics, IAT summary statistics, byte and packet rates, and burstiness. These flow-window features

MQTT/TLS observability policies for IoT traffic

LAM-MQTT separates hidden MQTT application fields from encrypted-flow behavior available near the broker

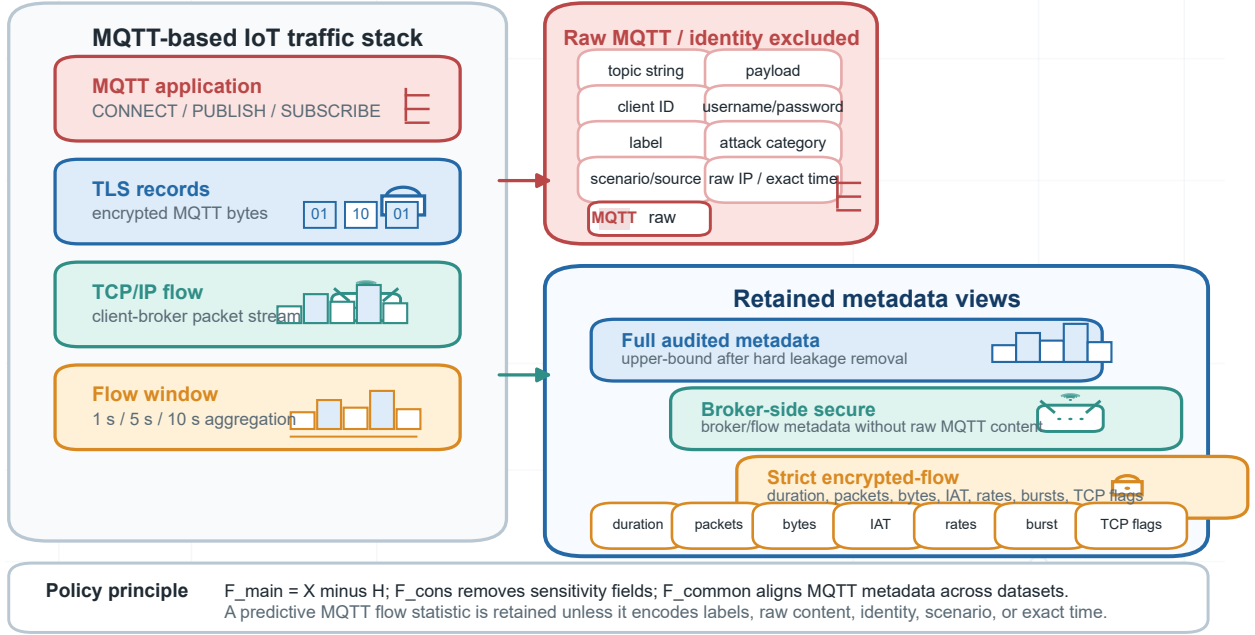


Fig. 3: MQTT/TLS observability policies for metadata-only IDS. Raw MQTT application and identity fields are excluded, while full audited, broker-side secure, and strict encrypted-flow views retain progressively constrained flow metadata available near the MQTT broker.

provide the primary strict encrypted-flow representation for MQTTEEB-D, whereas the packet-level strict view is treated as a weak baseline.

The raw timestamp is used only to assign packet records to windows and to derive duration and IAT statistics. It is not retained as a model input. For binary labels, a window is labeled as attack when any record in the window is labeled as attack. For multiclass labels, the window label follows the majority class within the window, and mixed-label information is used only for aggregation diagnostics.

G. Evaluation Protocol

The conservative sensitivity policy removes additional highly discriminative metadata to test whether performance depends on a small set of strong flow signals. This policy is a stress test, not the main deployment claim. The evaluated tasks include binary classification and multiclass classification when supported by the dataset labels. The model families include linear and tree-based baselines, with Macro F1 used as the primary metric. Accuracy is reported in the underlying metric tables but is not emphasized because IDS benchmarks are often class-imbalanced [48], [49].

The primary within-dataset protocol uses a 70/15/15 random stratified split with seed 42. Time-block splits are treated as formal performance only when the resulting test block contains at least two classes; invalid time-block rows are excluded from official performance interpretation. Cross-dataset experiments

train on one MQTT dataset view and test on another using common metadata. IoT-23 experiments are treated as external IoT robustness validation rather than MQTT-to-MQTT transfer. The implementation records all processed feature views and metric tables for reproducibility.

IV. EXPERIMENTS AND RESULTS

A. Finding 1: Audited encrypted-flow metadata supports strong within-dataset detection

Table II summarizes the main within-dataset results, and Fig. 4 visualizes Macro F1 for the packet-level MQTTEEB-D and biflow MQTT-IoT audited views. The MQTTEEB-D packet-level and flow-window results are different feature granularities. At packet level, metadata is informative but challenging; the best binary random-stratified result is 0.6549 Macro F1 with full or broker-side metadata, and the strict packet-level weak baseline reaches 0.6450. After flow-window aggregation, the MQTTEEB-D 5 s strict encrypted-flow representation reaches 0.8925 Macro F1. This comparison shows that the 0.6450 and 0.8925 values should not be interpreted as the same setting.

MQTT-IoT-IDS2020 shows much stronger within-dataset separability after hard leakage removal. Audited metadata reaches 0.9991 Macro F1 for binary classification and 0.9992 for multiclass classification across full, broker-side, and strict views. These results demonstrate strong in-distribution sep-

TABLE II: Within-dataset Macro F1 under audited metadata. Packet-level and flow-window rows are separate feature granularities.

Dataset/granularity	Task	View	Macro F1
MQTTEEB-D packet	binary	full/broker	0.6549
MQTTEEB-D packet	binary	strict	0.6450
MQTTEEB-D flow 5 s	binary	strict	0.8925
MQTTEEB-D packet	multiclass	full/broker	0.5595
MQTTEEB-D packet	multiclass	strict	0.5327
MQTT-IoT bifold	binary	all views	0.9991
MQTT-IoT bifold	multiclass	all views	0.9992

Dataset sources: MQTTEEB-D [45]; MQTT-IoT-IDS2020 [46].

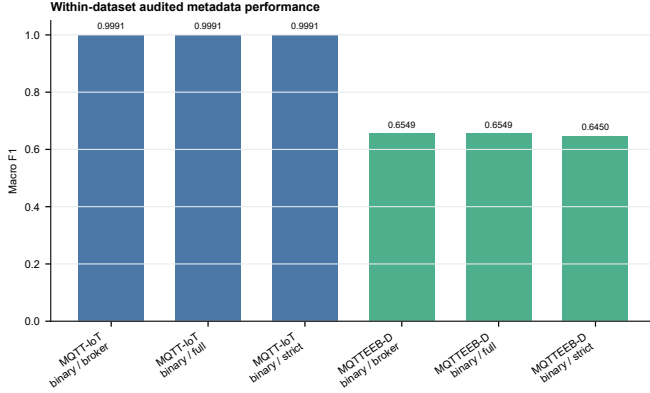


Fig. 4: Within-dataset Macro F1 for packet-level MQTTEEB-D and MQTT-IoT bifold audited views. MQTTEEB-D flow-window results are reported separately.

ability under the evaluated splits, but they do not imply unconditional deployment generalization.

B. Finding 2: Conservative sensitivity reduces MQTT-IoT performance

The conservative policy reduces MQTT-IoT strict features from 42 to 14. Binary Macro F1 decreases from 0.9991 under the audited main policy to 0.9684, and multiclass Macro F1 decreases from 0.9992 to 0.9489. This indicates that the most discriminative metadata features drive much of the detection ability. The decrease should be interpreted as sensitivity to removing legitimate flow metadata, not as proof that those metadata fields are label leakage.

C. Finding 3: Crypto-observability ablation favors the MQTTEEB-D 5 s strict flow window

Table III and Fig. 5 report the crypto-observability ablation. For MQTTEEB-D, strict flow-window metadata substantially improves over packet-level strict metadata. The 1 s strict flow view reaches 0.8693 Macro F1, the 5 s strict view reaches 0.8925, and the 10 s strict view reaches 0.8709. Among the tested MQTTEEB-D windows, the 5 s strict view performs best. For MQTT-IoT, audited full, broker-side, and strict encrypted-flow views all reach 0.9991 Macro F1, while the conservative strict view reaches 0.9684.

TABLE III: Crypto-observability and conservative sensitivity results. Packet-level strict and flow-window strict results are separate feature granularities.

Dataset/view	Policy	Macro F1
MQTTEEB-D packet	strict	0.6450
MQTTEEB-D flow 1 s	strict	0.8693
MQTTEEB-D flow 5 s	strict	0.8925
MQTTEEB-D flow 10 s	strict	0.8709
MQTT-IoT bifold	strict audited	0.9991
MQTT-IoT bifold	conservative	0.9684

Dataset sources: MQTTEEB-D [45]; MQTT-IoT-IDS2020 [46].

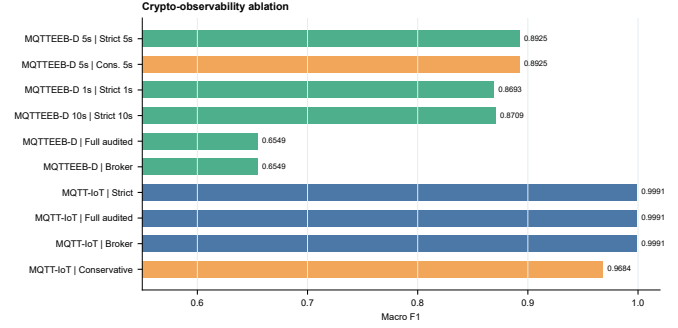


Fig. 5: Crypto-observability ablation under audited and conservative feature policies.

TABLE IV: MQTT-to-MQTT cross-dataset Macro F1 with 14 common metadata features. MQTTEEB-D rows denote flow-window settings.

Train	Test	Macro F1
MQTT-IoT	MQTTEEB-D 1 s	0.6417
MQTT-IoT	MQTTEEB-D 5 s	0.7312
MQTT-IoT	MQTTEEB-D 10 s	0.8172
MQTTEEB-D 1 s	MQTT-IoT	0.9140
MQTTEEB-D 5 s	MQTT-IoT	0.2735
MQTTEEB-D 10 s	MQTT-IoT	0.2149

Dataset sources: MQTTEEB-D [45]; MQTT-IoT-IDS2020 [46].

D. Finding 4: MQTT-to-MQTT transfer is asymmetric and window-dependent

Table IV and Fig. 6 report MQTT-to-MQTT transfer with the 14 common metadata features. Training on MQTT-IoT and testing on MQTTEEB-D flow windows gives 0.6417 Macro F1 for the 1 s window, 0.7312 for the 5 s window, and 0.8172 for the 10 s window. The reverse direction is uneven: MQTTEEB-D 1 s to MQTT-IoT reaches 0.9140, but MQTTEEB-D 5 s and 10 s to MQTT-IoT reach only 0.2735 and 0.2149, respectively. These results support a bounded conclusion: common encrypted-flow metadata can transfer in selected settings, but MQTT-to-MQTT generalization is not uniformly strong.

E. Finding 5: IoT-23 external robustness remains modest

IoT-23 is used only as external IoT robustness validation. MQTTEEB-D 5 s strict metadata transferred to IoT-23 with 0.4720 Macro F1, while MQTT-IoT strict metadata transferred

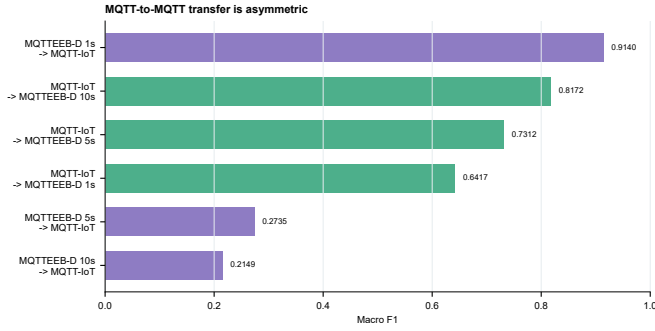


Fig. 6: Bidirectional MQTT-to-MQTT cross-dataset Macro F1 under common encrypted-flow metadata.

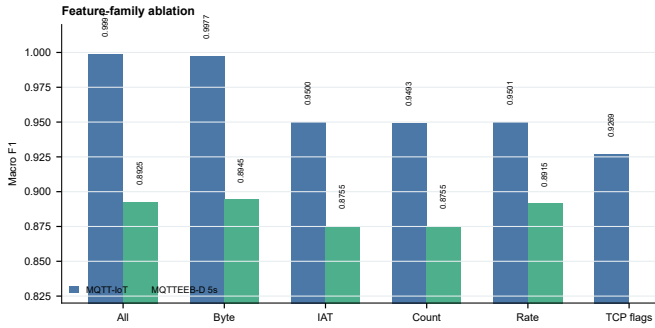


Fig. 7: Feature-family ablation for MQTT-IoT and MQTTEEB-D strict 5 s metadata.

to IoT-23 with 0.5076. These values are modest compared with within-dataset MQTT results and indicate out-of-domain IoT shift.

Feature-family ablation further clarifies the metadata signal. Fig. 7 shows that byte, IAT, packet-count, rate, burstiness, and TCP-related families carry meaningful information. For MQTT-IoT, all metadata reaches 0.9991, byte statistics alone reach 0.9977, IAT-only reaches 0.9500, packet-count-only reaches 0.9493, rate-only reaches 0.9501, and TCP-flags-only reaches 0.9269. For MQTTEEB-D 5 s strict metadata, all metadata reaches 0.8925, byte statistics alone reach 0.8945, rate features reach 0.8915, IAT-only reaches 0.8755, and packet-count-only reaches 0.8755.

Feature importance should be interpreted with the ablation rather than as causal proof. Fig. 8 shows model-level importance for top metadata features. Multi-seed stability is consistent with the main findings: MQTTEEB-D strict 5 s binary reports 0.8862 ± 0.0051 Macro F1, MQTT-IoT strict binary reports 0.9993 ± 0.0001 , MQTT-IoT to MQTTEEB-D strict 5 s reports 0.7464 ± 0.0310 , and MQTTEEB-D strict 5 s to MQTT-IoT reports 0.1994 ± 0.0536 .

V. CONCLUSION

This paper presented LAM-MQTT, a leakage-audited metadata-only evaluation framework for encrypted MQTT traffic. The framework removes hard leakage and sensitive raw fields while retaining legitimate encrypted-flow metadata. Within-dataset results show that such metadata can support

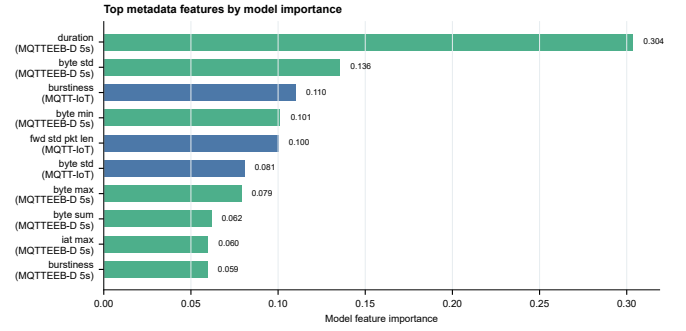


Fig. 8: Model-level feature importance for metadata-based IDS. Importance is model-level evidence and should not be interpreted as causal attribution.

effective MQTT-IoT attack detection, particularly on MQTT-IoT-IDS2020, while MQTTEEB-D benefits from flow-window construction.

The conservative sensitivity and feature-family ablation indicate that byte statistics, IAT statistics, rates, burstiness, and related flow behavior are core signals under the evaluated settings. These features should not be confused with label leakage solely because they are predictive. At the same time, MQTT-to-MQTT transfer asymmetry and modest IoT-23 robustness indicate operational shift across datasets and deployment contexts.

Future work should evaluate additional MQTT captures, real broker deployments, valid group or time-separated splits, and online edge deployment. Metadata-only IDS should be viewed as a deployment-compatible detection layer under cryptographic observability constraints, not as a replacement for cryptographic authentication, access control, or protocol hardening.

DATA AND CODE AVAILABILITY

The study uses public datasets: MQTTEEB-D, MQTT-IoT-IDS2020, and IoT-23. The source code, configuration files, leakage-audit rules, feature-view construction scripts, processed metric tables, and figure-generation scripts are available at: <https://github.com/DunLi-Tsinghua/LAM-MQTT>. The original raw datasets are not redistributed in the repository and should be obtained from their official sources, subject to their respective access and redistribution terms. The implementation records feature views, leakage audit decisions, processed metrics, and figures for reproducibility. The method does not decrypt TLS traffic and does not replace authentication, access control, or protocol hardening. Sensitive raw fields such as payloads, topics, credentials, client identifiers, raw IP identities, and exact timestamps are excluded from model inputs.

REFERENCES

- [1] *MQTT Version 5.0*, OASIS Std., 2019. [Online]. Available: <https://docs.oasis-open.org/mqtt/mqtt/v5.0/mqtt-v5.0.html>
- [2] E. Sisinni, A. Saifullah, S. Han, U. Jennehag, and M. Gidlund, "Industrial internet of things: Challenges, opportunities, and directions," *IEEE Transactions on Industrial Informatics*, vol. 14, no. 11, pp. 4724–4734, 2018.

- [3] K. P. Dyer, S. E. Coull, T. Ristenpart, and T. Shrimpton, "Peek-a-boo, i still see you: Why efficient traffic analysis countermeasures fail," in *2012 IEEE Symposium on Security and Privacy*. IEEE, 2012, pp. 332–346.
- [4] E. Rescorla, "The transport layer security (tls) protocol version 1.3," Internet Engineering Task Force, RFC 8446, 2018. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc8446>
- [5] J. Hayes and G. Danezis, "k-fingerprinting: A robust scalable website fingerprinting technique," in *25th USENIX Security Symposium (USENIX Security 16)*. Austin, TX: USENIX Association, 2016, pp. 1187–1203. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity16/technical-sessions/presentation/hayes>
- [6] X. Lin, G. Xiong, G. Gou, Z. Li, J. Shi, and J. Yu, "Et-bert: A contextualized datagram representation with pre-training transformers for encrypted traffic classification," in *Proceedings of the ACM Web Conference 2022*. ACM, 2022, pp. 633–642.
- [7] T. Karagiannis, K. Papagiannaki, and M. Faloutsos, "BLINC: Multilevel traffic classification in the dark," in *Proceedings of ACM SIGCOMM*, 2005, pp. 229–240. [Online]. Available: <https://www.caida.org/archive/networking/bib/entries/karagiannis05blinc/>
- [8] G. Draper-Gil, A. H. Lashkari, M. S. I. Mamun, and A. A. Ghorbani, "Characterization of encrypted and vpn traffic using time-related features," in *Proceedings of the International Conference on Information Systems Security and Privacy*, 2016, pp. 407–414.
- [9] D. Li, H. Li, N. Crespi, R. Minerva, M. Li, W. Liang, and K.-C. Li, "Hyper-IIoT: A smart contract-inspired access control scheme for resource-constrained industrial internet of things," *IEEE Transactions on Sustainable Computing*, vol. 10, no. 5, pp. 820–829, 2025.
- [10] D. Li, N. Crespi, R. Minerva, W. Liang, K.-C. Li, and J. Kołodziej, "DPS-IIoT: Non-interactive zero-knowledge proof-inspired access control towards information-centric industrial internet of things," *Computer Communications*, vol. 233, p. 108065, 2025.
- [11] D. Arp, E. Quiring, F. Pendlebury, A. Warnecke, F. Pierazzi, C. Wressnegger, L. Cavallaro, and K. Rieck, "Dos and don'ts of machine learning in computer security," in *Proceedings of the USENIX Security Symposium*, 2022, pp. 3971–3988. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity22/presentation/arp>
- [12] F. Pendlebury, F. Pierazzi, R. Jordaney, J. Kinder, and L. Cavallaro, "TESSERACT: Eliminating experimental bias in malware classification across space and time," in *Proceedings of the USENIX Security Symposium*, 2019. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity19/presentation/pendlebury>
- [13] M. A. Al-Garadi, A. Mohamed, A. K. Al-Ali, X. Du, I. Ali, and M. Guizani, "A survey of machine and deep learning methods for internet of things security," *IEEE Communications Surveys & Tutorials*, vol. 22, no. 3, pp. 1646–1685, 2020.
- [14] F. Hussain, R. Hussain, S. A. Hassan, and E. Hossain, "Machine learning in iot security: Current solutions and future challenges," *IEEE Communications Surveys & Tutorials*, vol. 22, no. 3, pp. 1686–1721, 2020.
- [15] E. Hodo, X. Bellekens, A. Hamilton, C. Tachtatzis, and R. Atkinson, "Shallow and deep networks intrusion detection system: A taxonomy and survey," *arXiv preprint arXiv:1701.02145*, 2017. [Online]. Available: <https://arxiv.org/abs/1701.02145>
- [16] D. Li, D. Han, N. Crespi, R. Minerva, S. M. Raza, R. Farahbakhsh, W. Liang, and Z. Zheng, "Blockchain in the digital twin context: A comprehensive survey," *ACM Computing Surveys*, vol. 58, no. 6, pp. 1–35, 2025.
- [17] I. Vaccari, G. Chiola, M. Aiello, M. Mongelli, and E. Cambiaso, "MQTTset, a new dataset for machine learning techniques on MQTT," *Sensors*, vol. 20, no. 22, p. 6578, 2020. [Online]. Available: <https://www.mdpi.com/1424-8220/20/22/6578>
- [18] Canadian Institute for Cybersecurity, "CICIoT2023: A Real-Time Dataset and Benchmark for Large-Scale Attacks in IoT Environment," Dataset, 2023. [Online]. Available: <https://www.unb.ca/cic/datasets/iotdataset-2023.html>
- [19] A. Alsaedi, N. Moustafa, Z. Tari, A. Mahmood, and A. Anwar, "TON_IoT telemetry dataset: A new generation dataset of iot and iiot for data-driven intrusion detection systems," *IEEE Access*, vol. 8, pp. 165 130–165 150, 2020.
- [20] N. Koroniotis, N. Moustafa, E. Sitnikova, and B. Turnbull, "Towards the development of realistic botnet dataset in the internet of things for network forensic analytics: Bot-iiot dataset," *Future Generation Computer Systems*, vol. 100, pp. 779–796, 2019.
- [21] Y. Meidan, M. Bohadana, Y. Mathov, Y. Mirsky, D. Breitenbacher, A. Shabtai, and Y. Elovici, "N-BaIoT: Network-based detection of iot botnet attacks using deep autoencoders," *IEEE Pervasive Computing*, vol. 17, no. 3, pp. 12–22, 2018.
- [22] M. A. Ferrag, O. Friha, D. Hamouda, L. Maglaras, and H. Janicke, "Edge-IIoTset: A new comprehensive realistic cyber security dataset of iot and iiot applications," *IEEE Access*, vol. 10, pp. 40 281–40 306, 2022.
- [23] M. Antonakakis, T. April, M. Bailey, M. Bernhard, E. Bursztein, J. Cochran, Z. Durumeric, J. A. Halderman, L. Invernizzi, M. Kallitsis, D. Kumar, C. Lever, Z. Ma, J. Mason, D. Menscher, C. Seaman, N. Sullivan, K. Thomas, and Y. Zhou, "Understanding the mirai botnet," in *Proceedings of the USENIX Security Symposium*, 2017. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity17/technical-sessions/presentation/antonakakis>
- [24] C. Kolias, G. Kambourakis, A. Stavrou, and J. Voas, "DDoS in the IoT: Mirai and other botnets," *Computer*, vol. 50, no. 7, pp. 80–84, 2017.
- [25] A. W. Moore and D. Zuev, "Internet traffic classification using bayesian analysis techniques," in *Proceedings of ACM SIGMETRICS*, 2005, pp. 50–60. [Online]. Available: <https://www.cl.cam.ac.uk/research/srg/netos/projects/archive/nprobe/data/papers/sigmetrics/index.html>
- [26] M. Conti, L. V. Mancini, R. Spolaor, and N. V. Verde, "Analyzing android encrypted network traffic to identify user actions," *IEEE Transactions on Information Forensics and Security*, vol. 11, no. 1, pp. 114–125, 2016.
- [27] V. F. Taylor, R. Spolaor, M. Conti, and I. Martinovic, "AppScanner: Automatic fingerprinting of smartphone apps from encrypted network traffic," in *Proceedings of the IEEE European Symposium on Security and Privacy*, 2016, pp. 439–454.
- [28] M. Lotfollahi, M. Jafari Siavoshani, R. Shirali Hossein Zade, and M. Saberian, "Deep packet: A novel approach for encrypted traffic classification using deep learning," *Soft Computing*, vol. 24, pp. 1999–2012, 2020.
- [29] S. Rezaei and X. Liu, "Deep learning for encrypted traffic classification: An overview," *IEEE Communications Magazine*, vol. 57, no. 5, pp. 76–81, 2019.
- [30] G. Aceto, D. Ciunzo, A. Montieri, and A. Pescapé, "Mimetic: Mobile encrypted traffic classification using multimodal deep learning," *Computer Networks*, vol. 165, 2019.
- [31] W. Wang, M. Zhu, X. Zeng, X. Ye, and Y. Sheng, "Malware traffic classification using convolutional neural network for representation learning," in *Proceedings of the International Conference on Information Networking*, 2017, pp. 712–717.
- [32] M. Lopez-Martin, B. Carro, A. Sanchez-Esguevillas, and J. Lloret, "Network traffic classifier with convolutional and recurrent neural networks for internet of things," *IEEE Access*, vol. 5, pp. 18 042–18 050, 2017.
- [33] A. Sivanathan, H. H. Gharakheili, F. Loi, A. Radford, C. Wijenayake, A. Vishwanath, and V. Sivaraman, "Classifying IoT devices in smart environments using network traffic characteristics," *IEEE Transactions on Mobile Computing*, vol. 18, no. 8, pp. 1745–1759, 2019.
- [34] R. Sommer and V. Paxson, "Outside the closed world: On using machine learning for network intrusion detection," in *Proceedings of the IEEE Symposium on Security and Privacy*, 2010, pp. 305–316.
- [35] M. Ring, S. Wunderlich, D. Scheuring, D. Landes, and A. Hotho, "A survey of network-based intrusion detection data sets," *Computers & Security*, vol. 86, pp. 147–167, 2019.
- [36] J. Quinero-Candela, M. Sugiyama, A. Schwaighofer, and N. D. Lawrence, Eds., *Dataset Shift in Machine Learning*. MIT Press, 2009.
- [37] S. J. Pan and Q. Yang, "A survey on transfer learning," *IEEE Transactions on Knowledge and Data Engineering*, vol. 22, no. 10, pp. 1345–1359, 2010.
- [38] I. Sharafaldin, A. Habibi Lashkari, and A. A. Ghorbani, "Toward generating a new intrusion detection dataset and intrusion traffic characterization," in *Proceedings of the International Conference on Information Systems Security and Privacy*, 2018, pp. 108–116.
- [39] N. Moustafa and J. Slay, "UNSW-NB15: A comprehensive data set for network intrusion detection systems," *Proceedings of the Military Communications and Information Systems Conference*, 2015.
- [40] A. Sperotto, G. Schaffrath, R. Sadre, C. Morariu, A. Pras, and B. Stiller, "An overview of IP flow-based intrusion detection," *IEEE Communications Surveys & Tutorials*, vol. 12, no. 3, pp. 343–356, 2010. [Online]. Available: <https://research.utwente.nl/en/publications/an-overview-of-ip-flow-based-intrusion-detection/>
- [41] M. F. Umer, M. Sher, and Y. Bi, "Flow-based intrusion detection: Techniques and challenges," *Computers & Security*, vol. 70, pp. 238–254, 2017.
- [42] P. Garcia-Teodoro, J. Diaz-Verdejo, G. Macia-Fernandez, and E. Vazquez, "Anomaly-based network intrusion detection: Techniques, systems and challenges," *Computers & Security*, vol. 28, no. 1–2, pp. 18–28, 2009.

- [43] M. Ahmed, A. N. Mahmood, and J. Hu, "A survey of network anomaly detection techniques," *Journal of Network and Computer Applications*, vol. 60, pp. 19–31, 2016.
- [44] Y. Mirsky, T. Doitshman, Y. Elovici, and A. Shabtai, "Kitsune: An ensemble of autoencoders for online network intrusion detection," in *Proceedings of the Network and Distributed System Security Symposium*, 2018. [Online]. Available: https://www.ndss-symposium.org/wp-content/uploads/2018/02/ndss2018_03A-3_Mirsky_paper.pdf
- [45] "MQTTEEB-D: A Real-World IoT Cybersecurity Dataset for AI-Powered Threat Detection in MQTT Networks," Mendeley Data, 2025. [Online]. Available: <https://data.mendeley.com/datasets/jfttfjn6tr/1>
- [46] H. Hindy, E. Bayne, M. Bures, R. Atkinson, C. Tachtatzis, and X. Bellekens, "Machine learning based iot intrusion detection system: An mqtt case study," *arXiv preprint arXiv:2006.15340*, 2020. [Online]. Available: <https://arxiv.org/abs/2006.15340>
- [47] Stratosphere Laboratory, "IoT-23: A Labeled Dataset of Malware and Benign IoT Traffic," Dataset, 2020. [Online]. Available: <https://www.stratosphereips.org/datasets-iot23>
- [48] A. L. Buczak and E. Guven, "A survey of data mining and machine learning methods for cyber security intrusion detection," *IEEE Communications Surveys & Tutorials*, vol. 18, no. 2, pp. 1153–1176, 2016.
- [49] A. Khraisat, I. Gondal, P. Vamplew, and J. Kamruzzaman, "Survey of intrusion detection systems: Techniques, datasets and challenges," *Cybersecurity*, vol. 2, no. 20, 2019. [Online]. Available: <https://link.springer.com/article/10.1186/s42400-019-0038-7>